NOTAT

# Datasikkerhed, GDPR og jurisdiktion ved brug af amerikansk AI-værktøj i fjernvarme-businesscases

*Dansk Fjernvarme · Maj 2026 · Udkast v1*


## Sammenfatning

Dansk Fjernvarme har via et pilotprojekt med Billund Varmeværk udviklet en metode hvor domæneeksperter på fjernvarmeværker bygger driftsoptimeringsmodeller i samarbejde med AI-assistenten Claude (Anthropic, USA). Metoden er åbnet for medlemsnetværket. Brugen rejser tre adskilte spørgsmål om datasikkerhed:

- **Persondata under GDPR** — driftsdata indeholder typisk ikke personoplysninger og kan håndteres med aggregering før upload.
- **Kommerciel fortrolighed** — håndteres ved at fravælge model-træning (forbruger-plan) eller ved at bruge en kommerciel plan med Data Processing Addendum.
- **Adgang fra amerikanske myndigheder** (CLOUD Act, FISA 702) — en strukturel eksponering der ikke kan kontraheres væk hos amerikanske udbydere. Sandsynligheden er meget lav for almindelige driftsdata, men forholdet skal indgå i værkernes NIS2-leverandørstyring.

*Det anbefales at metoden anvendes med en defineret data-minimeringspraksis, og at strategisk og sikkerhedskritisk materiale holdes udenfor værktøjet.*


## 1. Baggrund

Pilotprojektet på Billund Varmeværk har vist at en domæneekspert uden programmeringsbaggrund kan bygge en operationel driftsoptimeringsmodel ved at samarbejde med en AI-assistent. Modellen kvantificerer værdien af eksisterende og fremtidige investeringer i akkumulering, varmepumper og elkedler — herunder værdien af at deltage i balancemarkederne. Metode, kode og dokumentation er stillet til rådighed for medlemsnetværket under en open-source MIT-licens.

Det AI-værktøj der konkret er anvendt — Claude fra Anthropic — er en amerikansk tjeneste. Når metoden udbredes til medlemsnetværket, går spørgsmålet om datasikkerhed og GDPR igen blandt værkerne. Dette notat samler de tre dimensioner som bestyrelsen/ledelsen bør være orienteret om.

## 2. De tre risikodimensioner

### 2.1 Persondata under GDPR

GDPR beskytter identificerbare individer. Den datapakke der typisk anvendes i en businesscase indeholder ikke personoplysninger, men anlægsspecifikationer, aggregeret timeproduktion på værksniveau, markedsdata fra Energinet, vejrdata fra DMI, og kontraktpriser. Det der skal undgås — og som modellen ikke har behov for — er kunde-niveau forbrugsdata, herunder individuelle målerdata, CPR-numre og fakturaoplysninger. Aggregering til værksniveau før upload håndterer denne risiko.

### 2.2 Kommerciel fortrolighed

Det største praktiske spørgsmål handler ikke om GDPR i snæver forstand, men om kommerciel fortrolighed: brændselskontrakter, leverandøraftaler, balancestrategi og fremtidige investeringsovervejelser.

Anthropics aktuelle politik (verificeret maj 2026):

| Plan | Træning på data | Opbevaring | Databehandleraftale |
|---|---|---|---|
| **Free / Pro / Max** | Opt-in (kan slås fra) | 30 dage ved fravalg, ellers op til 5 år | Nej |
| **Team / Enterprise** | Nej (aldrig) | Aftalt | Ja, m. SCC'er |
| **API / Bedrock / Vertex** | Nej (aldrig) | Kundekontrol / aftalt | Ja, m. SCC'er |

Anthropic er ISO 27001- og ISO 42001-certificeret. EU-brugere er beskyttet af GDPR uanset plan, og Standard Contractual Clauses (EU standardkontrakter) dækker overførsler til USA i de kommercielle aftaler. For uformelt udviklingsarbejde med ikke-kritiske data er en Pro-konto med træning fravalgt tilstrækkelig. Hvis et værk vil bruge værktøjet til daglige forretningsbeslutninger med kommercielt sensitive data, bør et Team-abonnement eller en API-baseret opsætning overvejes — det giver en formel Databehandleraftale og udelukker træning kontraktuelt.

### 2.3 Adgang fra amerikanske myndigheder

Dette er den dimension, der ikke kan kontraheres væk for amerikanske udbydere. Tre amerikanske love giver myndighederne potentiel adgang til data uanset hvor data fysisk ligger:

- **CLOUD Act (2018)** — udleveringskendelser i kriminelle sager, gælder amerikanske moderselskaber globalt.
- **FISA Section 702** — efterretningsmæssig overvågning af ikke-amerikanske personer udenfor USA, fornyet og udvidet i april 2024.
- **Executive Order 12333** — bulk-indsamling af data udenfor USA med begrænset tilsyn.

EU-US Data Privacy Framework (2023) løser ikke disse eksponeringer juridisk. EU-residens hos AWS eller Google ændrer ikke på det amerikanske moderselskabs forpligtelser, og flere europæiske datatilsyn har i 2025–2026 vurderet konkrete sager hvor SCC'er ikke fandtes tilstrækkelige.

For fjernvarmesektoren skal proportionerne med: Sandsynligheden for at amerikanske myndigheder rekvirerer driftsdata fra et dansk fjernvarmeværk er meget lav i normal drift. CLOUD Act bruges typisk i kriminelle efterforskninger; FISA 702 retter sig mod udenlandske efterretningsmål. Almindelige drifts- og markedsdata er ikke i den kategori. Risikoen er strukturel og juridisk reel, men praktisk set lav for det datagrundlag modellen anvender.

## 3. Forholdet til NIS2

Fjernvarme er kritisk infrastruktur under EU's NIS2-direktiv. Direktivet stiller krav til forsyningskædesikkerhed og leverandørrisikovurdering, og brug af AI-værktøjer skal indgå i værkets generelle leverandørstyring på linje med øvrige cloud- og IT-tjenester. Det betyder konkret at hvert værk bør dokumentere hvilke datatyper der deles og ikke deles, hvilken plan/aftale der anvendes, og begrundelsen for at brugen er proportional.

## 4. Anvendt praksis i pilot- og udbredelsesfasen

I Billund-pilotprojektet og i den vejledning der distribueres med modellen, anvendes følgende principper:

- **Dataminimering.** Kun aggregerede driftsdata, markedsdata og anlægsspecifikationer uploades. Ingen kunde-niveau data.
- **Træning fravalgt.** Privacy-indstillingen sættes så samtaler ikke bruges til model-træning, og retention reduceres til 30 dage.
- **Kommerciel sensitivitet håndteres separat.** Forhandlingspositioner, kontraktvilkår overfor specifikke modparter og strategiske beslutningsoplæg holdes udenfor værktøjet.
- **NIS2-relevant materiale udelukkes.** Detaljerede anlægstegninger med sårbarhedspunkter, SCADA-arkitektur og beredskabsplaner deles ikke med værktøjet.

## 5. Anbefaling

1. Metoden kan udbredes i medlemsnetværket på den nuværende form, idet ovenstående principper kommunikeres tydeligt sammen med modellen og brugervejledningen.
2. Værker der ønsker at gå længere — fx integrere AI-værktøjet i daglige forretningsbeslutninger med kommercielt sensitive data — bør gennemføre en formel leverandørvurdering og overveje et kommercielt abonnement med DPA.
3. Dansk Fjernvarme følger udviklingen i EU-US Data Privacy Framework og kommunikerer ændringer hvis det juridiske grundlag ændrer sig væsentligt.

4. Det undersøges om en europæisk-baseret AI-leverandør på sigt kan tilbyde sammenlignelig funktionalitet, som en parallel mulighed for værker med skærpede krav til dataresidens og jurisdiktion. Dette er pt ikke tilfældet.

---

*Notatet er et arbejdsudkast og forventes opdateret når Anthropics politik, EU-US Data Privacy Framework eller relevante tilsynspraksis ændrer sig.*